

CSCI302 Cybersecurity

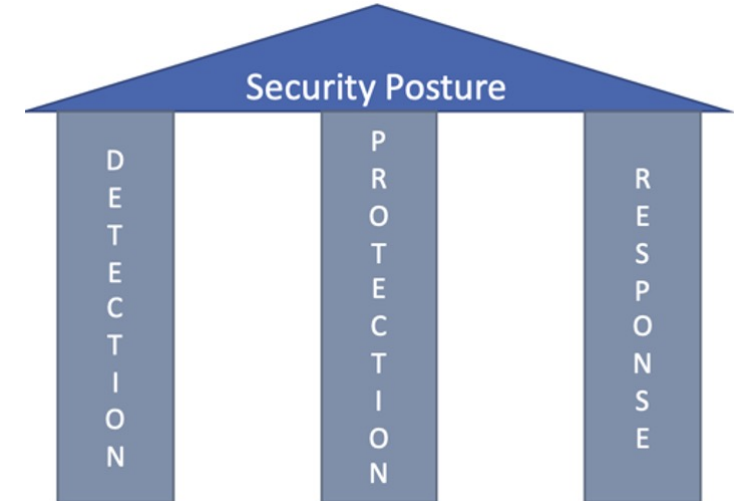
Revision/Summary



UNIVERSITY
OF WOLLONGONG
AUSTRALIA

Security Posture

- Security Posture
 - Threat Landscape - On-premise, BYOD (Bring Your Own Device), Cloud and Personal Devices
 - The Credential - Continuous monitoring and MFA
 - Security considerations taken to
 - ✓ Apps developed in house
 - ✓ Apps users are paying for as a service
- Cyber Security Challenge
 - Targeted Attack, Ransomware and Data as a weapon.
- Red Team and Blue Team
 - Concepts, Performances metrics



Incident Response Process

- Incident Response Process
 - Creating IR Process - Fundamental Area of IR Process
- Incident (Response) life Cycle
 - Preparation, detection, containment and Post-incident Activity
 - IR life cycle update with the cloud
- Threat Life Cycle Management - 6 Phases
- Cybersecurity Kill Chain – 5 Steps
- WannaCry – Tools / How it works.

Reconnaissance/ Compromising Systems

- External Reconnaissance
 - Dumpster Diving
 - Social Media - Identity Theft
 - Social Engineering
 - ✓ Six levers of Social Engineering.
 - ✓ Several social engineering attacks.
- Internal Reconnaissance
 - Tools for Internal Reconnaissance
- Compromising Systems - The current trends of attack
 - Extortion attacks, Data manipulation attacks, Backdoors, IoT device attacks, Mobile device attacks, Hacking every devices, Hacking the cloud
- Stuxnet and Flame

Chasing a User's Identity

- Chasing a user's identity
 - Identity is the new perimeter – BYOD, Cloud Computing
 - SMB Relay Attacks to steal credential
 - ✓ Hash Function (its concept and 3 key properties)
 - ✓ How this attack works?
- Strategies for compromising a user's identity
 - Three steps that the red team should consider.
 - Some important considerations in on-premises environments (for the red team)
 - Harvesting credentials – Unpatched vulnerability and Pass-the-Hash
 - Hacking User's Identity – Bruteforce, Social Engineering and Pass-the-Hash
- Steps to Compromising Systems
 - Deploy the payloads
 - Compromise the operating systems
 - Compromise the web-based systems

Lateral Movement

- Lateral Movement
 - Sniffing Tools to do network mapping
 - ✓ Nmap
 - ✓ Why is network mapping possible? NIDS vs HIDS
 - Avoiding alerts
- Performing Lateral Movement - Windows
 - Tools, like Sysinternals, Active Directory

Privilege Escalation

- Privilege Escalation
 - Horizontal Privilege escalation
 - ✓ Two main ways - Through 1) Software Bugs and 2) an administrator account
 - Vertical Privilege escalation
 - ✓ Avoid alerts
 - ✓ Exploit unpatched operating system, Access token manipulation, Application shimming, Attacks using DLL, Exploiting vulnerabilities
- Concluding the mission
 - Exfiltration
 - Sustainment
 - Assault
 - Obfuscation

Malware & Attack Technologies

- Malware Classification
- What are the characteristics of different types of Malware?
 - Virus, Worms, Trojans, Backdoor, Ransomware
- Countermeasures for Malware

Law Regulation

- General Data Protection Regulation (GDPR)
 - Who makes GDPR?
 - What is its purpose or what are protected by GDPR?
 - What is personal data?
 - What is the territorial scope of it?
 - Key Principles of GDPR
- Australian Privacy Act 1988
 - 13 Australian Privacy Principles
 - ✓ E.g., in APP2, what are Anonymity and Pseudonymity?

Digital Forensics

- What are digital forensics?
- Data Forensics VS Data Recovery (They are different!)
- Investigations Triad for Computer Security
- History of Digital Forensics
- What should a successful digital forensics investigator do?
- What measures business can do to reduce the risk of litigation?
- How to secure your evidence when preparing a company policy violation investigation?

Differential Privacy

- What is the purpose of differential privacy?
- What is the main idea of designing DP schemes?
 - How it works?
 - ✓ For each query, returning an answer with noise
 - ✓ What is the consequence if we just return an answer without noise?

Network Segmentation

- Defense-in-depth approach
- Network segmentation
 - Example: Virtual Local Area Network (VLAN) based on department
Advantage? Disadvantage?
- Mixed VLAN approach: VLAN designed based on various aspects such as location, business objectives and level of sensitivity
- Network Access Control (NAC)
- Site-to-Site VPN: A private channel of communication between the main corporation network and the remote network
- Hybrid cloud

Active Sensors

- Traditional defender mindset vs new mindset in relation to monitoring users.
- Indicator of Compromise (IoC) – Major IoCs
- Host-Based IDS vs Network-Based IDS
- Signature-Based IDS vs Behavior-based IDS
- IDS vs IPS (Intrusion Prevention System)
- Anomaly-Based IPS
- Behavior Analytics

Threat Intelligence and Investigating Incident

- The areas where the information obtained from (cyber) threat intelligence can be used?
 - Profiling motivations, analyzing attacker tactics, analyzing techniques, Assessing operations
- Examples of profiling motivation of the attacker
- Alert triage
- Investigating an Incident
 - Scoping, Key Artifacts, On-premises compromised system, Cloud-based compromised system, Lessons learned

Recovery Process

- Disaster recovery plan
 - Definition, objectives, benefits, challenges
- Live recovery
- Contingency plan
 - Definition
 - Five steps of IT contingency planning process
- Best practices
 - Having an offsite location, keeping record of any changes, implementing fault-tolerant systems, regularly testing the process of restoring a stem from backups

Vulnerability Management

- Asset inventory
- Information management
- Risk assessment
 - Vulnerability analysis
 - Threat analysis
- Vulnerability assessment - Definition, challenges
- The role of remediation phase
- An important consideration in reporting phase
- Best Practices for Vulnerability Management

Security Policy

- What security policies should include
 - Industry standards, procedures, guidelines and best practices
 - Well-defined scopes
- Differences of Policy, Procedure, Standard, Guidelines and Best Practices
- The security awareness program
- Hardening via the Common Configuration Enumeration (CCE) list
- Policy Enforcement
 - GPO (Group Policy Objective): Definition / how it can be used
 - Whitelisting

Sample Questions

➤ Q1. Which is (are) an incorrect statement(s) from the following?

- 1. The amount of time required for a "targeted attack" is usually short.
- 2. As government-sponsored cyber attacks happen on a large scale, the private sector can ignore them.
- 3. Estimated Time to Detection (ETTD) is one of the metrics for which the Red team has accountability.
- 4. The traditional "prevent breach" approach promotes ongoing testing.
- 5. There is no way for an attacker to compromise two factor authentication.
- A) 1, 3 and 5
- B) All of the options
- C) 5
- D) 1, 2, 3 and 5
- E) 2, 3, 4 and 5

Sample Questions

➤ Q2. Which is (are) an incorrect statement(s) from the following?

- 1. Metasploit provides many exploits and payloads for network attacks.
- 2. msvenom can generate a payload for a backdoor.
- 3. Data manipulation attacks can happen when there is a lack of a mechanism for checking the integrity of data.
- 4. Fuzzing is originally a software testing technique, which provides valid inputs to a given program to see how it reacts to the inputs.
- 5. Smartphones' web-supported apps can be exploitable through the man-in-the-middle attack.
- A) 2 and 3
- B) 1, 2 and 4
- C) None of the options
- D) 1 and 3
- E) 1, 2, 3 and 4

Sample Questions

➤ Q3. Which is (are) an incorrect statement(s) from the following?

- 1. Network Intrusion Detection System (NIDS) shields an organisation's system to prevent internal reconnaissance even when the hackers are scanning individual targets.
- 2. By using legitimate tools for lateral movement, hackers can move around in highly secured networks.
- 3. Sysinternals gives alerts to users on a remote system when it is in operation.
- 4. Sysinternals can be used to reveal information about running processes.
- 5. Windows PowerShell can be used as a legitimate tool for lateral movement.
- A) 1
- B) 3
- C) 1 and 3
- D) 2 and 4
- E) 1, 4 and 5

Sample Questions

- Q4. What is an example of profiling motivation, from which a group of hackers expresses a political preference to just an expression for a particular cause?
- Q5. Explain the three entities of CIA Triad.

On Final

- There are up to 50 questions
 - MCQ and Short Answer Questions included.
- Coverage: All the week's lecture and tutorial notes.
- **Closed book exam**